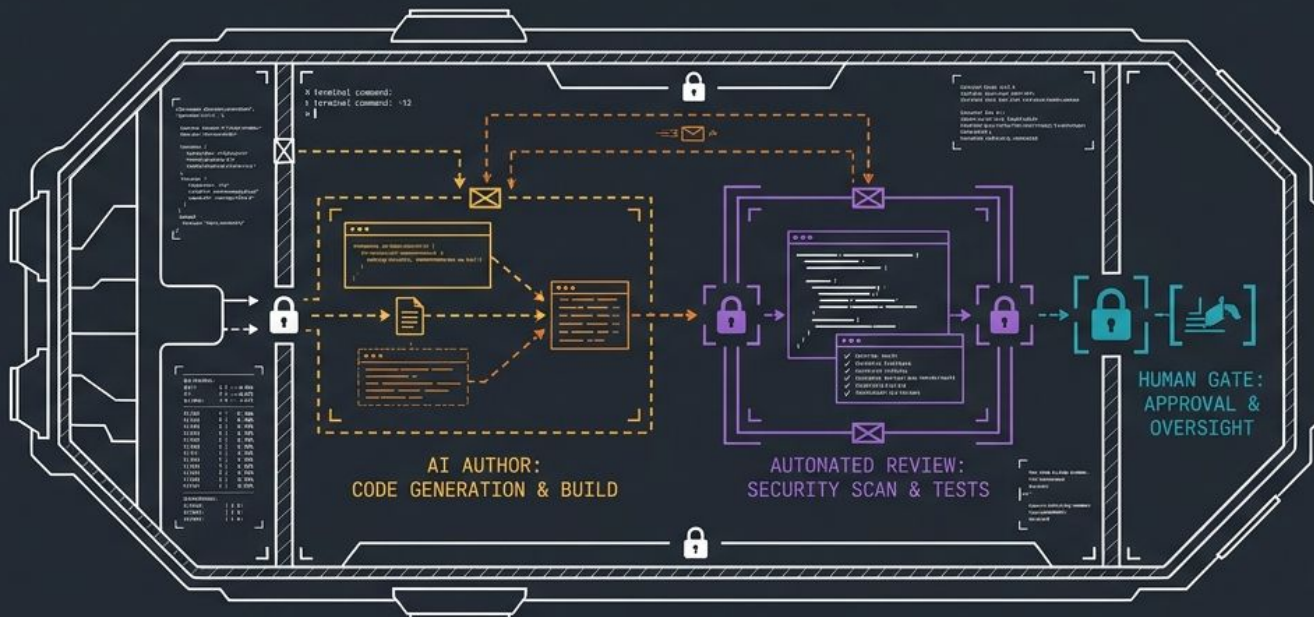


Governing AI Agents in Production

Lessons learned from building Risk Trainer at zero cost using multi-vendor AI workflows.

- Human Gate
- AI Author
- Automated Review
- System Boundary



[TARGET: \$0.00 MONTHLY SPEND | AUTOMATED TESTS: 376 | COVERAGE: 98.38%]

The Crucible: Risk Trainer

The Application

CORE LOGIC

CISSP risk prioritization simulator. 5 findings, 2 remediation slots, 4 strict risk treatments (Avoid, Mitigate, Transfer, Accept).

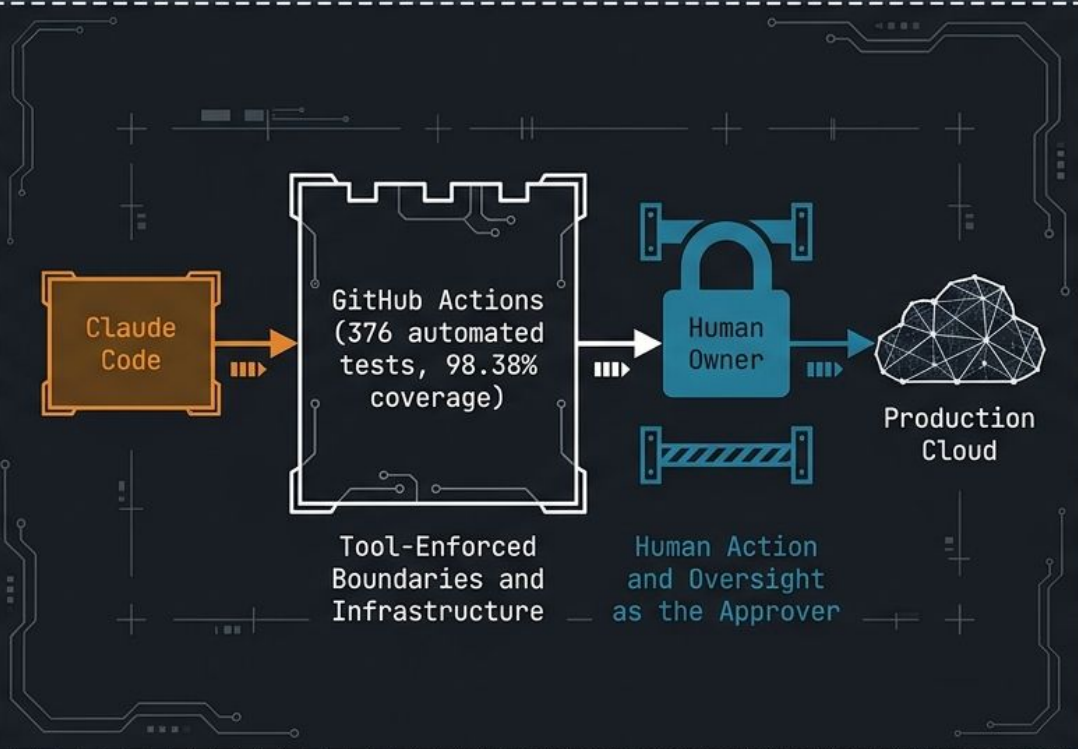
THE CONSTRAINT

Built to run at exactly \$0 cost beyond an existing Claude subscription.

THE STACK

AWS (CloudFront, Lambda, DynamoDB), Python 3.14, Mangum adapter, Terraform.

The Meta-Architecture



The Illusion vs. The Reality of AI Development

Instruction-Based Trust (High Risk)



Tool-Enforced Production Governance (Zero Trust)

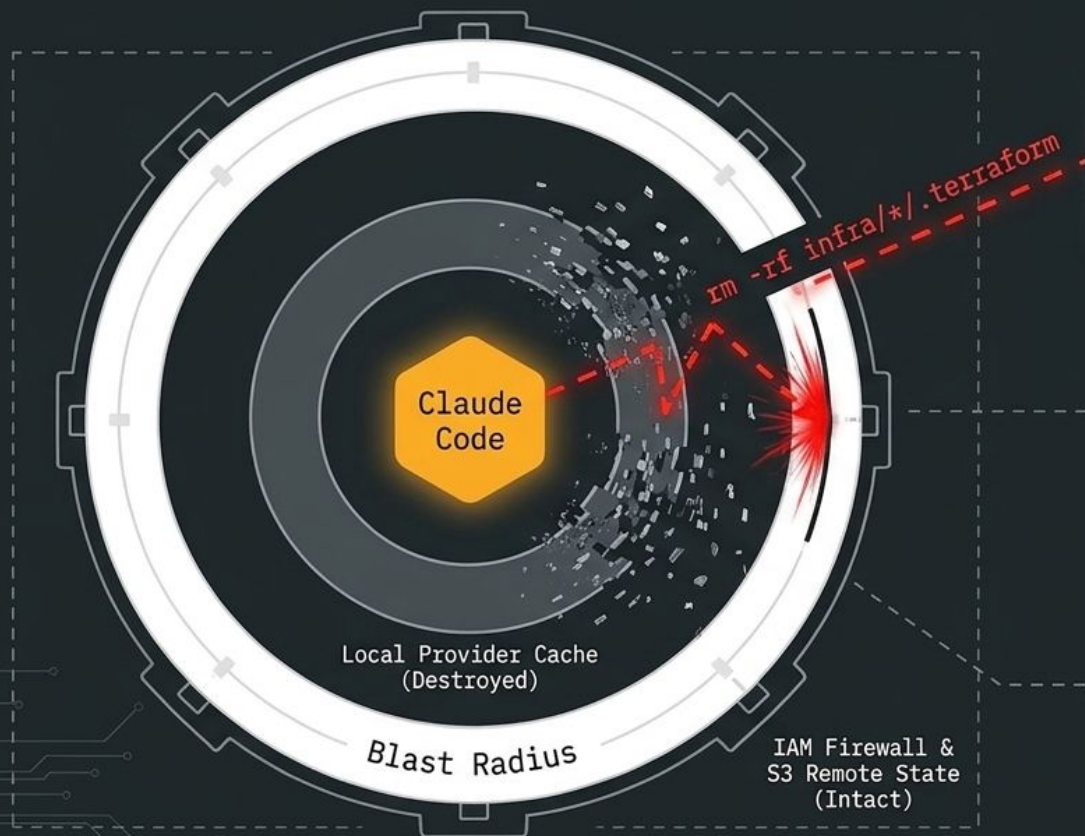


[The Multi-Vendor Separation of Duties Matrix]

Task	Assigned Entity	Access Level	The Human Gate
Spec & Build	 Claude Code	Read/Write (Local)	 Human reviews spec & plan before code changes.
Spec Challenge	 ChatGPT (Free)	Read-Only	 Human arbitrates 15 raised findings (13 accepted).
Content Fact-Check	 Perplexity (Free)	Read-Only	 Human manually checks citations against NIST SP 800-39.
Pull Request Review	 Claude Github Agent + CodeQL + Semgrep	Read-Only (Inline Comments Only)	 Human resolves conversations; ruleset blocks merge.

Key Insight: The entity writing the code never has the authority to review it or merge it. Vendor independence guarantees objective friction.

Incident Anatomy: 6 Oct 2026



THE ACTION:

The coding agent executes a broad cleanup command with a wildcard.

THE RESULT: The local Terraform bootstrap folder is deleted. The AWS Cloud state remains completely untouched.

THE LESSON: Instructions ("be careful") are not a control. Agents will make destructive mistakes; the architecture must contain them.

[Moving from Instructions to Tool-Enforced Constraints]

Weak Control: Prompting

~~Never delete the bootstrap folder or
run destructive commands.~~



Fails when models hallucinate or optimize for speed.

Strong Control: `.claude/settings.json`

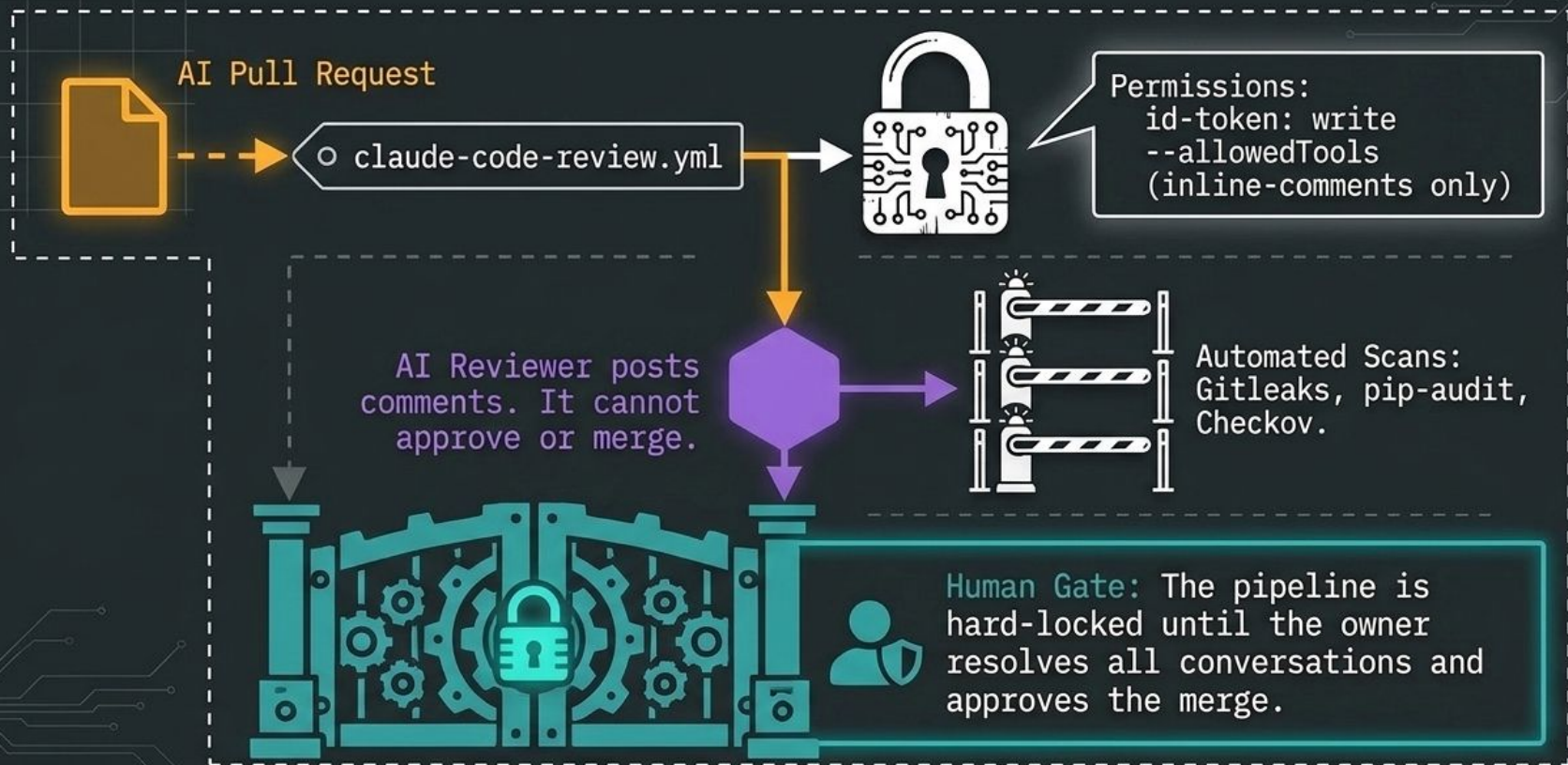


```
Deny: Edit(/infra/bootstrap/**)  
Deny: Bash(rm -rf *)
```



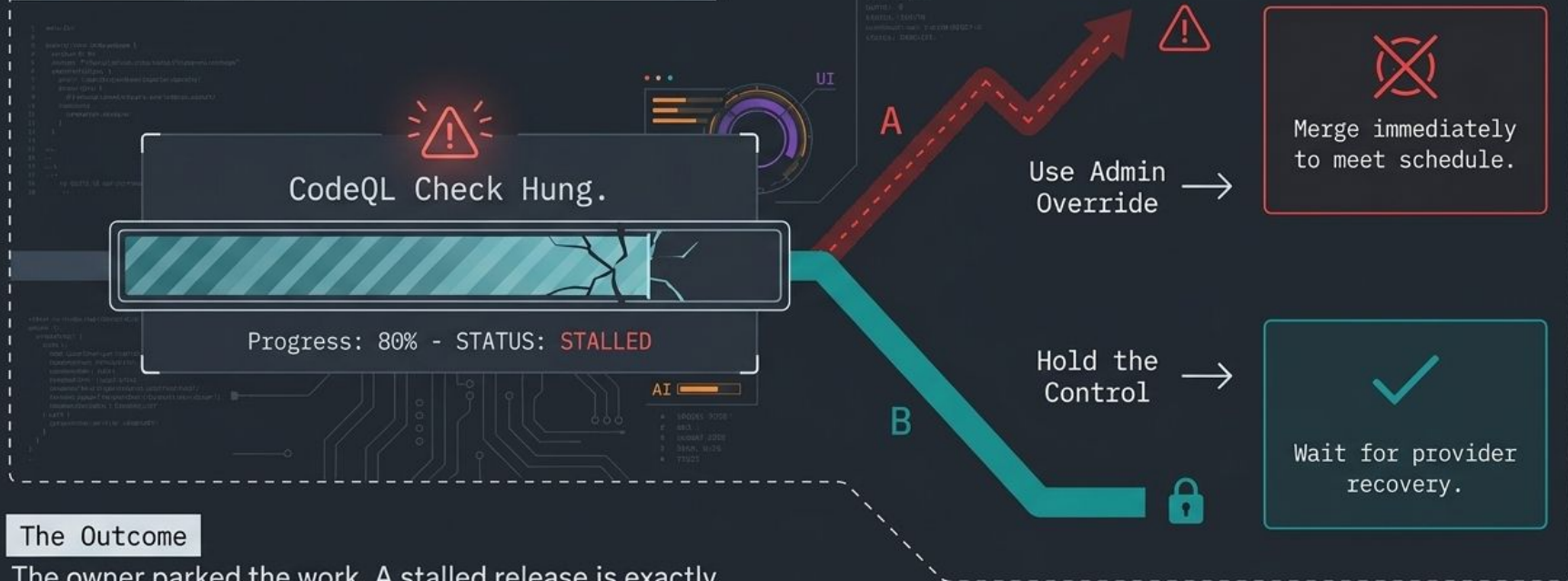
Tool-Enforced Governance: The agent physically cannot override these constraints, regardless of the prompt. When the bootstrap folder later needed a fix, the agent wrote a patch file, and the human applied it.

[Designing the Human Gate (CI/CD)]



Holding the Line Under Pressure

The Event: 5 Oct 2026 - GitHub Actions Outage



The Outcome

The owner parked the work. A stalled release is exactly when teams are tempted to skip security scans. The rule was held. Once GitHub recovered, an empty commit triggered a fresh scan, merging with every check green.

[Identity & Access: Debugging OIDC Federation]

⚠️ The Problem: `configure-aws-credentials` fails during the first production deploy.

```
/----- CloudTrail Logs - {cloudtrail} 2024-10-30 17:51:2921 -----  
[ {  
  "Expected Trust Policy": "repo:dustenatx/risk-trainer:...",  
},  
  "Actual CloudTrail Subject": "repo:dustenatx@54679392/risk-trainer@1398551921...",  
}  
] ===== Logs "CloudTrail" =====  
]----- CloudTrail 2023-01-21T130:56.073077-96U Fuc"00"679602" -----
```

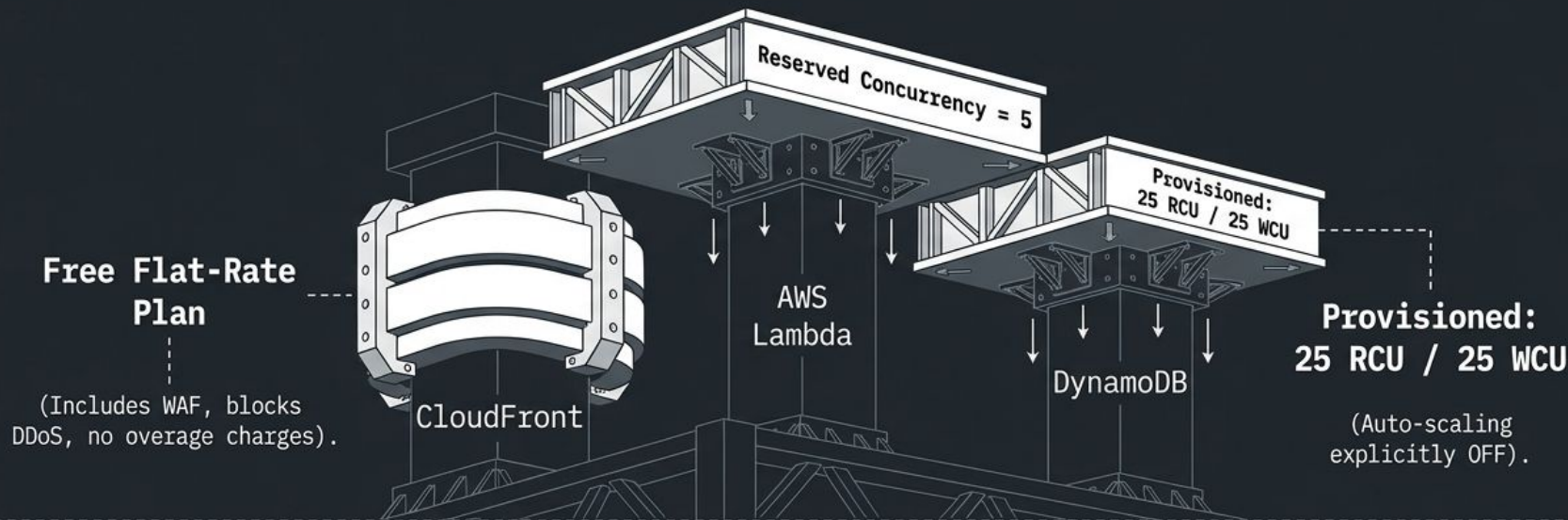
[The Architectural Fix]

Instead of reverting to name-based policies, the policy is updated to match the immutable subject format.

[Why it matters]

Numeric IDs cannot be hijacked by an attacker re-registering a deleted repository name. Security was increased, not bypassed, to fix the error.

Cost Architecture is Governance

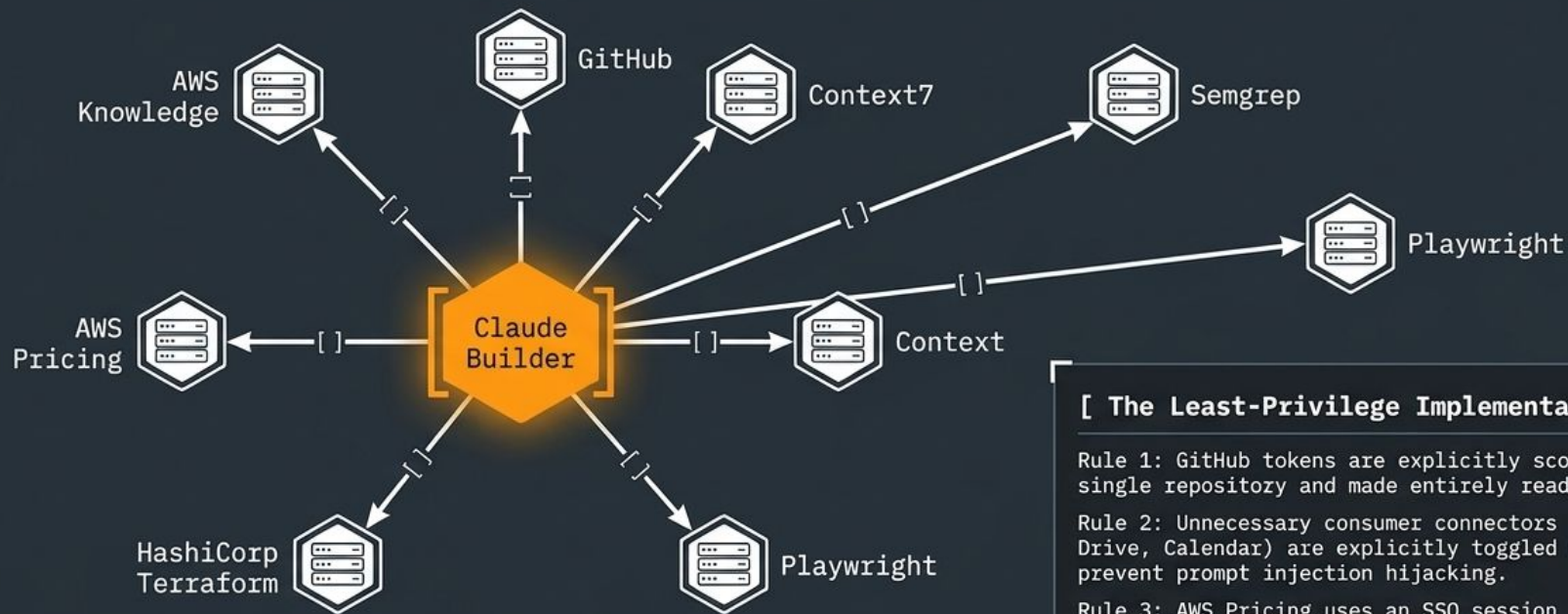


The Takeaway: **Soft alerts** (AWS Budgets) only detect spend drift.

Hard ceilings (Concurrency & Provisioning) enforce safety.

A flood of malicious traffic results in automated throttling, not an infinite bill.

[Scoping the Model Context Protocol (MCP)]



[The Least-Privilege Implementation]

Rule 1: GitHub tokens are explicitly scoped to a single repository and made entirely read-only.

Rule 2: Unnecessary consumer connectors (Google Drive, Calendar) are explicitly toggled OFF to prevent prompt injection hijacking.

Rule 3: AWS Pricing uses an SSO session restricted strictly to pricing:* read access.

Core Precept: Scope the credentials, not the prompt.
Asking a model to 'only read' is not a security control.

The Authoring MCP: Security by Omission

Available Tools

STATUS: **ENABLED**

- `get_schema`
- `list_scenarios`
- `validate_scenario`
- `score_answers`
- `save_draft`

(Hard-coded to write only to content/drafts/)

STATUS: **ENABLED**

The Missing Tool

STATUS: **NOT CONFIGURED**

`approve_scenario`

STATUS: **NOT CONFIGURED**

The Insight

The server exposes no tool capable of approving or publishing content. The **human approval gate** is enforced by the **physical absence** of the tool, guaranteeing the AI agent cannot bypass the human owner.

Shifting Cost and Risk: The Learner MCP

[While you build]



[In the product]



Key Takeaway: The application makes zero LLM calls itself. By exposing a stateless, rate-limited /mcp endpoint, the user's own AI subscription processes the coaching, maintaining the \$0 application cost constraint.

The AI Control Paradigm Matrix

Instruction-Based Governance (The Old Way)

Relies on Prompt Engineering ("Tell the AI to be safe").



```
prompt {  
  "preapt = "I",  
  "kat is renmeter",  
  "Tell the AI to be safe"  
}
```

Single-model dependence
(AI grades its own homework).



Read/Write Access to
the entire environment.



Human acts as the
Prompter.



Production Governance (The Risk Trainer Way)

Relies on Tool-Enforced
Constraints (Deny rules,
physical ceilings).



```
deny {  
  rules: {  
    "deny_access = "deny",  
    "deny_access = "physica"  
  }  
}
```

DENY

Multi-Vendor Workflows
(Objective friction via
distinct tools).



Least Privilege via
strict MCP scoping.



Human acts as
the Approver.



The New Blueprint



1

AI is not an autonomous creator; it is a managed contractor.

(Separate duties. The entity that writes the code cannot review or review or deploy it.)



2

Instructions are not controls.

(Architect boundaries that the AI physically cannot cross. Enforce safety through IAM, CI/CD gates, and tool omission.)



3

Cost architecture is security architecture.

(Build hard ceilings, not just alerts. Financial limits mitigate operational blast radiuses.)

EXIT CODE 0: GOVERNANCE ESTABLISHED.